

团 体 标 准

T/TAF 267.4—2025

软件开发工具包（SDK）用户权益和个人信息保护技术要求 第4部分：支付类

Technical requirements for user rights and personal information
protection of Software Development Kits (SDK)—
Part 4: Payment category

2025-02-10 发布

2025-02-10 实施

电信终端产业协会 发布

目 次

前言 II

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 个人信息处理要求 1

 4.1 收集要求 1

 4.2 存储要求 2

 4.3 使用、加工要求 2

 4.4 传输要求 2

 4.5 共享要求 2

 4.6 删除要求 2

5 用户权益保护要求 3

6 业务功能划分及配置能力提供要求 3

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是T/TAF 267《软件开发工具包（SDK）用户权益和个人信息保护技术要求》的第4部分。T/TAF 267已发布了以下部分：

- 第1部分：广告类；
- 第2部分：推送类；
- 第3部分：地图类；
- 第4部分：支付类；
- 第5部分：统计类。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由电信终端产业协会提出并归口。

本文件起草单位：中国信息通信研究院、蚂蚁科技集团股份有限公司、北京快手科技有限公司、阿里巴巴（中国）有限公司、荣耀终端股份有限公司、北京火山引擎科技有限公司、友盟同欣（北京）科技有限公司。

本文件主要起草人：常浩伦、李鑫、汪坤、石玉珍、臧磊、郭文双、卢利颖、顾世鸿、陈鑫爱、王春瑶、白晓媛、落红卫、黄天宁、赵晓娜、李辰淑、李思凡、姚栋、贾紫薇。

软件开发工具包（SDK）用户权益和个人信息保护技术要求

第4部分：支付类

1 范围

本文件规定了支付类 SDK 的个人信息处理要求、用户权益保护要求和业务功能划分及配置能力提供要求。

本文件适用于支付类 SDK 开发运营者规范自身个人信息处理活动，同时也适用于主管部门、第三方评估机构等对支付类 SDK 个人信息保护和用户权益保护能力进行监督和评估。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

T/TAF 188—2023 软件开发工具包（SDK）收集个人信息技术要求

T/TAF 189—2023 软件开发工具包（SDK）用户权益保障基本要求

3 术语和定义

T/TAF 188—2023、T/TAF 189—2023界定的以及下列术语和定义适用于本文件。

3.1

软件开发工具包开发运营者 software development kit operator

软件开发工具包的开发者、所有者、管理者或提供者，也包括SDK相关的个人信息处理者。

注：简称SDK开发运营者

3.2

移动互联网应用程序开发运营者 mobile internet application operator

移动互联网应用程序的开发者、所有者、管理者或提供者，也包括App相关的个人信息处理者。

注：简称SDK使用者。

4 个人信息处理要求

4.1 收集要求

支付类SDK在个人信息收集过程中，除满足T/TAF 188—2023、T/TAF 189—2023相关要求外，还应满足以下收集要求：

- a) 应仅在支付流程被触发时，收集相关个人信息，不应在最终用户未发起或完成支付后收集个人

信息，具有合理场景或者服务所必需的除外；

- b) 收集个人信息用于保障最终用户的账户和资金安全的，应在最小范围内收集用户个人信息，对可能收集的可变更设备唯一标识（如 Android ID、OAID）、不可变更的唯一设备标识（如 MAC 地址、IMEI 号）、基本设备信息（如设备型号、设备品牌、操作系统信息）、软件安装列表以及网络信息（IP 地址、网络类型、运营商信息、Wi-Fi 状态、Wi-Fi 参数、Wi-Fi 列表）等，应合理划分必要和可选信息范围；
- c) 宜在该 SDK 对应的支付 APP 中收集用户交易相关信息，为保障最终能在多种业务场景下（如最终用户未安装该 SDK 对应的支付 APP）顺利完成支付，支付类 SDK 收集的交易相关信息，包括内嵌该 SDK 的 APP 信息、订单编号、商品名称、商品金额、商品数量、交易时间、订单过期时间、卖家 ID 等，应根据实际支付情况、与 SDK 使用者的协议要求等因素合理确定信息数量；
- d) 需进行人脸、指纹等生物信息核验身份的，应具有合理的场景；
- e) 聚合其他第三方支付 SDK 的，应对第三方 SDK 个人信息保护能力进行评估，选择对最终用户影响最小的方式合理配置第三方 SDK 各项可选功能及可选个人信息。

4.2 存储要求

支付类SDK在个人信息存储过程中应满足以下要求：

- a) 在中国境内收集和产生的个人信息，要向境外传输的，应当符合国家关于数据出境的要求。
- b) 不宜在客户端存储最终用户交易相关个人信息，在服务端存储的用户交易相关个人信息，应采取严格的加密、访问控制等措施，避免个人信息泄露；
- c) 仅提供聚合支付服务的 SDK，不应在当次支付完成后留存用户相关个人信息，法律法规另有规定的除外。

4.3 使用、加工要求

支付类SDK应仅在获得最终用户同意或满足其他合法性基础的前提下，才可使用、加工个人信息。

4.4 传输要求

支付类SDK传输个人信息的要求如下：

- a) 传输个人信息时应当采取必要的安全措施；
- b) 涉及敏感个人信息传输时，支付类 SDK 使用者应采取数据加密、安全传输通道或安全传输协议进行数据传输。

4.5 共享要求

支付类SDK在共享个人信息过程中应满足以下要求：

- a) 应在实现业务目的的最小必要范围内，向第三方（如银行等金融机构、银联/网联等清算机构）提供个人信息，并明确双方共享目的、共享的个人信息种类、双方的权利义务与责任分配；
- b) 应在 SDK 使用协议或个人信息处理规则中向 SDK 使用者和最终用户说明个人信息的共享目的、方式和范围；
- c) 应采取加密、脱敏等安全技术措施，保证个人信息在共享过程中的安全性，防止泄露、丢失或损毁。

4.6 删除要求

支付类SDK的个人信息删除要求如下：

- a) 当 SDK 使用者停止使用支付类 SDK 后,应及时移除支付类 SDK 相关代码,并通知支付类 SDK 开发运营者。支付类 SDK 开发运营者在收到 SDK 使用者通知后,应停止处理通过该 SDK 使用者收集到的个人信息,并按照双方约定内容履行个人信息删除或匿名化义务;
- b) 支付类 SDK 应在最终用户主动删除或依法请求删除个人信息时,及时响应并删除相关个人信息。未达法定保存期限或有其他法定事由需继续储存的除外;
- c) 法律法规规定的保存期限未届满或删除个人信息从技术上难以实现的,支付类 SDK 应当停止除存储和采取必要的安全保护措施之外的处理。

5 用户权益保护要求

支付类SDK用户权益保护要求如下:

- a) 支付类 SDK 应向 SDK 使用者提供其收集使用信息的详细说明(包括但不限于: SDK 提供方名称、收集的个人信息类型、使用目的、最终用户可浏览隐私说明的链接),并要求 APP 开发者在应用的显著位置或以其他可触达最终用户的方式告知最终用户;
- b) 支付类 SDK 应尊重个人信息相关权利,在 SDK 使用协议或个人信息处理规则中向 APP 开发者和最终用户说明行使个人信息权利的方式或渠道;
- c) 支付类 SDK 应保障最终用户的个人信息安全,采取有效的技术和管理措施,防止个人信息被泄露、丢失或损毁;
- d) 支付类 SDK 应及时响应最终用户个人信息相关的咨询、投诉、纠纷等请求;
- e) 支付类 SDK 应在下载页面或介绍页面,以醒目方式展示个人信息处理规则、合规使用说明的跳转链接;
- f) 支付类 SDK 支持免密支付服务的,在免密支付开通前,应在显著位置全面、准确地向最终用户告知免密支付规则,并获得最终用户同意,不得采用默认勾选、默认同意、捆绑销售等方式强制最终用户开通免密支付服务。

6 业务功能划分及配置能力提供要求

支付类SDK在向SDK使用者提供功能服务过程中应遵循以下要求:

- a) 支付类SDK应向SDK使用者提供取消免密支付的功能接口;
- b) 聚合其他第三方支付SDK的,应提供配置选择方式,供SDK使用者自主选择集成第三方SDK产品,宜提供配置选项,供SDK使用者控制开启与关闭第三方SDK的各项可选功能及可选个人信息。

电信终端产业协会团体标准

软件开发工具包（SDK）用户权益和个人信息保护技术要求
第4部分：支付类

T/TAF 267.4—2025

*

版权所有 侵权必究

电信终端产业协会印发

地址：北京市西城区新街口外大街28号

电话：010-82052809

电子版发行网址：www.taf.org.cn